NANYANG TECHNOLOGICAL UNIVERSITY SINGAPORE

SC4063 Network Security Report

Group No: 5

Full Name	Matriculation Number
Aaron Toh Sheng Rong	U2222943E
Koh Junyang Nicholas	U2222992D
Kuan Hong Hui Joy	U2221261D
Jasmine Tye Jia Wen	U2321408J
Liu Cong	U2321782E
Phoebe Lee Jia Ying	U2223881K
Yong Yik Sheng	U2322759F
Tan Bao Chen, Jess	U2222331K
Ng Yao Hong	U2220975H
Tan Wu Ji	U2222584L
Ong Hong Xun	U2321248G
Ong Chun Wei	U2321759C

A. Initial Access (Patient Zero)

A.1 Pre-Intrusion Reconnaissance and Probing

Before the confirmed intrusion on 2025-03-01, the available capture shows 5 hours 5 minutes of precursor activity, not multiple days. Within that limited window, 170 external IPs repeatedly probed the exposed RDP service on **10.128.239.57**, generating **52,911** inbound RDP connection attempts, which is consistent with background RDP spray activity on an internet-exposed host.

No separate pre-intrusion validation session attributable to the eventual attacker was captured. Instead, **195.211.190.189** first appears afterward as a focused, low-volume, credential-bearing RDP source immediately preceding the privileged **10.128.239.57 -> 10.128.239.29** sequence. This pattern is consistent with pre-validated credentials already being available before the capture window, rather than that source participating in the earlier broad spray activity.

Figure A.1 summarises the observed transition from external RDP access on 10.128.239.57 to internal authentication, pivot activity, and follow-on network operations.

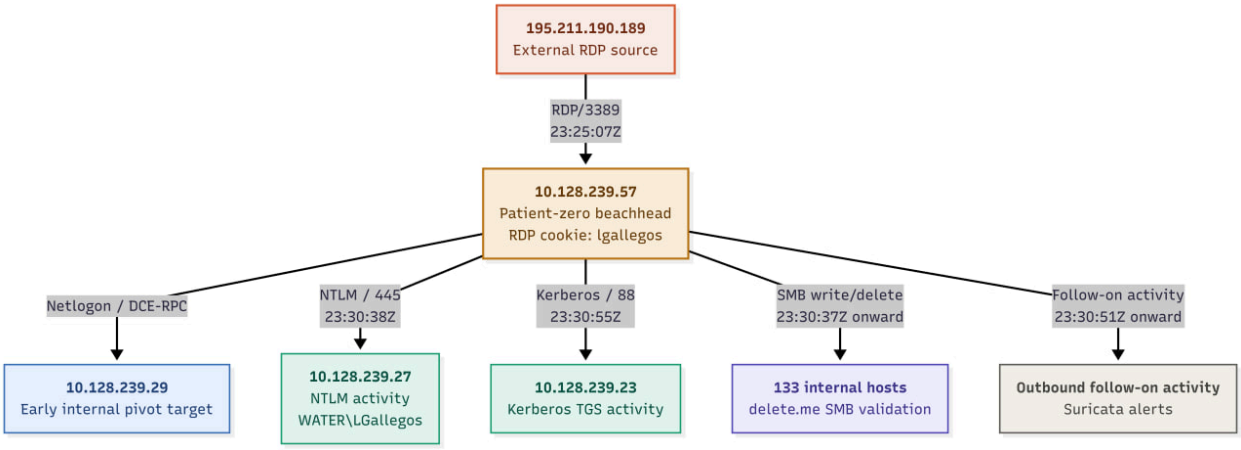

Figure A.1: Initial Access and Immediate Post-Compromise Activity

A.1.1 External Reconnaissance Activity

The pre-access telemetry does not show broad multi-port perimeter scanning or VPN reconnaissance. All observed external traffic to security-relevant ports in the available pre-boom window targeted 3389/tcp only. No inbound connections were observed to 443, 8443, 1194, 500, 4500, or 1723, further reinforcing that the visible initial access path in this incident was direct RDP rather than VPN.

The external activity against **10.128.239.57** was substantial and continuous. Between **2025-03-01T18:20:01.315Z** and **2025-03-01T23:25:36.515Z**, 170 external IPs generated 52,911 RDP connections. Nearly all of these were transport-layer-established sessions, with Zeek recording RSTO for 52,470 connections and only a single outright REJ. This indicates that

the RDP service was not merely discoverable but actively reachable and responsive to internet-originated traffic.

Several sources displayed strong scanner or spray-tool characteristics. For example, **141.98.11.170** repeatedly negotiated RDP while presenting cookies such as Administr and WATER\\Adm, while **45.140.17.72** repeatedly used the cookie jjjjjjjRD, which appears derived from the target hostname. These patterns are consistent with automated username or hostname-aware probing rather than normal administrative access. Multiple high-volume sources also shared a small number of repeated JA3 fingerprints across dozens of IP addresses, indicating coordinated or tool-reused scanning infrastructure rather than independent human operators.

A.1.2 Credential Testing and Validation

Despite the large amount of ambient RDP spray traffic, the confirmed intrusion source behaved differently from the background scanners. The eventual attacker IP, **195.211.190.189** (AS214943 Railnet LLC), does not appear as part of the earlier high-volume spray set within the March 1 precursor window. Instead, it first appears at **2025-03-01T23:25:07.989Z** as a low-volume inbound RDP session family to **10.128.239.57:3389**, followed by:

- 2025-03-01T23:25:08.120Z Zeek rdp
- 2025-03-01T23:25:26.037Z Zeek ssl
- 2025-03-01T23:25:36.515Z Zeek rdp with cookie lgallegos
- 2025-03-01T23:25:36.665Z Zeek ssl

The team did not observe multiple failed attempts from **195.211.190.189**, nor did we see a failed-then-success chain from that IP. Likewise, we did not observe a separate short-lived foothold session from a different IP that could be confidently labeled as an IAB validation login. Thus, the most likely interpretation is that the credentials were already known to work before the visible intrusion sequence began.

Unlike the broader background spray activity, this session family is low-volume, credential-bearing, and tightly coupled in time to the subsequent privileged internal activity from 10.128.239.57. That difference in behavior is what makes it the strongest candidate for the actual operator-led entry sequence.

A.1.3 Suricata and Detection Context

Suricata recorded limited but relevant pre-boom RDP-related alerts. The clearest example is source **96.126.120.149**, which triggered ET REMOTE_ACCESS Inbound RDP Connection with TLS Security Protocol Requested at **2025-03-01T20:07:57.473Z** and ET REMOTE_ACCESS Inbound RDP Connection with Minimal Security Protocol Requested at **2025-03-01T20:08:12.064Z**. These events indicate opportunistic RDP probing of the same exposed host, but they do not correlate to the final intrusion source.

Notably, the confirmed attacker IP did not trigger any Suricata alerts before the successful entry. The compromise therefore emerged from within a noisy background of internet RDP scanning rather than from a clean alertable precursor sequence (Figure A.2). This highlights the operational challenge of defending exposed RDP services without stronger access controls and authentication safeguards.

IP	First Seen	Last Seen	Attempts	Notes	Classification
141.98.11.170	2025-03-01T18:20:06.365Z	2025-03-01T23:24:29.094Z	6,589	Shared JA3 with 38 other IPs; repeated cookies like Administr, WATER\\Adm	Background RDP spray
194.0.234.17	2025-03-01T18:20:01.130Z	2025-03-01T23:25:35.657Z	6,512	Shared JA3 with 38 other IPs; many varied cookie strings	Background credential-spray/probing
179.60.146.33	2025-03-01T21:47:09.432Z	2025-03-01T23:25:35.830Z	2,365	Repeated hello cookie	Background scanner
45.135.232.124	2025-03-01T19:00:06.151Z	2025-03-01T23:25:35.195Z	1,741	Suricata malicious-IP hits; repeated cookie m	Background scanner
45.140.17.72	2025-03-01T19:07:19.956Z	2025-03-01T20:31:35.883Z	1,592	Repeated cookie jjjjjjjRD	Hostname-aware spray / scanner
96.126.120.149	2025-03-01T20:07:47.521Z	2025-03-01T20:08:12.125Z	3	Triggered Suricata ET REMOTE_ACCESS RDP alerts	Light probing

Table A.1: Representative External Sources in the Precursor Window

The initial access evidence indicates that the threat actor obtained access through a directly exposed RDP/3389 service on host **10.128.239.57** (jjjjjjjRDP02) . No network evidence of VPN-based ingress was observed. Instead, Zeek shows an inbound RDP session from **195.211.190.189** beginning at **2025-03-01T23:25:07.989Z**, followed by RDP cookie **lgallegos** at **2025-03-01T23:25:36.515Z**, after which 10.128.239.57 proceeds into privileged internal activity toward **10.128.239.29**. This supports the assessment that **10.128.239.57** was the patient-zero beachhead and that the attacker likely used already-valid credentials.

Attack Vector23:30:38

Zeek connection, rdp, and ssl telemetry show an inbound RDP session family from external IP **195.211.190.189** to **10.128.239.57:3389** beginning at **2025-03-01T23:25:07.989Z**, followed by a credential-bearing RDP event at **2025-03-01T23:25:36.515Z** with cookie **lgallegos**.
Within **6.969** seconds, the same internal host initiated a successful Kerberos AS request for lgallegos/water.domain-ees3Ai.local, strongly indicating that the attacker had already obtained valid credentials and used them immediately after gaining RDP access (Figure A.3). Shortly afterward, the beachhead host authenticated internally over NTLM as **WATER\\LGallegos**, and Suricata recorded early scanning behavior from the same host, consistent with hands-on-keyboard post-access activity.

Indicators of Compromise (IOCs)

Type	Value	Context	First Seen
IP Address	195.211.190.189	External low-volume RDP source preceding privileged internal activity	2025-03-01 23:25:07 UTC
IP Address	10.128.239.57	Patient-zero / beachhead host	2025-03-01 23:25:07 UTC
Port	3389/TCP	Initial access via exposed RDP	2025-03-01 23:25:07 UTC
Username-like value	lgallegos	RDP cookie observed in inbound session from 195.211.190.189	2025-03-01 23:25:36 UTC
Username-like value	Administr	Repeated RDP cookie in precursor spray/probing activity	2025-03-01 18:20:02 UTC
Username-like value	Admin	Repeated RDP cookie in precursor spray/probing activity	2025-03-01 18:20:02 UTC
Username-like value	WATER\Adm	Repeated RDP cookie in precursor spray/probing activity	2025-03-01 18:20:04 UTC
Username-like value	ecoborrow	RDP cookie observed in credential-aware probing activity	2025-03-01 20:06:30 UTC
Username-like value	user	RDP cookie observed in credential-aware probing activity	2025-03-01 20:06:30 UTC
Username-like value	administr	RDP cookie observed in credential-aware probing activity	2025-03-01 20:06:31 UTC
Username-like value	hello	Repeated RDP cookie in background scanner activity	2025-03-01 21:47:09 UTC
Username-like value	m	Repeated RDP cookie in background scanner activity	2025-03-01 19:00:02 UTC
Username-like value	jjjjjjjRD	Repeated RDP cookie in hostname-aware spray/probing activity	2025-03-01 19:07:19 UTC
Username-like value	Springfi3	Repeated RDP cookie in scripted probing activity	2025-03-01 23:20:02 UTC
IP Address	10.128.239.29	First privileged internal pivot target / likely domain controller	2025-03-01 23:25:43 UTC

Table A.2: List of indicators of compromise (IOC)

Detailed Timeline

Timestamp (UTC)	Source	Destination	Activity	Evidence Source
2025-03-01 23:25:07.989	195.211.190.189	10.128.239.57:3389	External connection to exposed RDP service	Zeek conn
2025-03-01 23:25:36.515	195.211.190.189	10.128.239.57:3389	RDP session observed; cookie lgallegos	Zeek rdp
2025-03-01 23:25:43.484	10.128.239.57	10.128.239.23:88	Successful Kerberos AS for lgallegos	Zeek kerberos
2025-03-01 23:25:43 - 23:26:47	10.128.239.57	10.128.239.29	Domain enumeration via LSARPC, LDAP and DRSUAPI (name resolution, SID lookup, directory queries)	Zeek dce_rpc
2025-03-01 23:30:38.026	10.128.239.57	10.128.239.27:445	NTLM authentication as WATER\LGallegos, followed by SMB administrative share access (IPC$, ADMIN$, C$)	Zeek ntlm
2025-03-01 23:30:40.286	10.128.239.57	10.128.239.0/24	Mass SMB admin-share probing initiated (delete.me operations across 133 hosts)	Zeek smb_files
2025-03-01 23:30:51.378	10.128.239.57	10.128.239.130:1433	Early internal scan activity detected	Suricata eve
2025-03-01 23:31:27.467	10.128.239.57	10.128.239.221:135	Additional internal scan activity detected	Suricata eve

2025-03-02 00:20:11.897	10.128.239.57	10.128.239.64:3389	First internal RDP pivot from beachhead host	Zeek rdp

Table A.3: Detailed timeline of events from 01-03-2025 23:25-00:20

Evidence
The most probative evidence is the tightly correlated sequence of events beginning with an inbound RDP session from **195.211.190.189** to **10.128.239.57** at **2025-03-01 23:25:07**, followed by an RDP session containing the cookie “lgallegos”. Within seconds, the compromised host initiated a successful Kerberos AS request for the same user, confirming that valid credentials were used immediately after access.

This was rapidly followed by domain-level enumeration activity, including LSARPC, LDAP, and DRSUAPI interactions with **10.128.239.29**, indicating that the attacker began querying directory services and resolving account and system information. Shortly thereafter, NTLM authentication was observed from **10.128.239.57** using the account **WATER\LGallegos**, followed by SMB administrative share access (IPC$, ADMIN$, and C$), confirming elevated privileges within the domain.

Critically, between **23:30:37** and **23:31:00**, a large-scale burst of SMB file operations involving a file named “delete.me” was observed. A total of **449** file operations were recorded across **133** internal hosts, all originating from **10.128.239.57**. These operations consisted of repeated file creation and deletion attempts on administrative shares, indicating automated validation of write access across the network.

This sequence demonstrates a clear progression from initial access to authenticated domain interaction, followed by privilege validation and rapid lateral movement across multiple hosts. Supporting host-identification records map **10.128.239.57** to jjjjjjjRDP02, and the RDP certificate subject CN=jjjjjjjRDP02 confirms that this system was the internet-facing RDP server used as the initial beachhead.

B. Lateral Movement & Discovery

B.1 Overview

Following initial access via RDP on host 10.128.239.57, the threat actor conducted extensive lateral movement and discovery across the internal network. The compromised host served as the primary beachhead from which all subsequent reconnaissance and lateral movement

originated. Combined analysis of Zeek sensor logs and PCAP files identified three distinct phases of activity spanning March 1, March 6, and March 8, 2025.

Key findings include: (1) SMB connections from the compromised host to 153 unique internal targets across the 10.128.239.0/24 subnet, with 1,444 SAMR enumeration operations targeting approximately 130 unique hosts; (2) interactive RDP sessions to 6 internal hosts; (3) RDP port scanning across 153 unique internal hosts; (4) ADMIN$ access to multiple domain controllers, constituting direct evidence of authenticated administrative lateral movement; and (5) cross-domain infrastructure mapping spanning the POWER, WATER, PARKS, and SAFETY domains within the Active Directory forest. All findings were cross-validated between Zeek logs and raw PCAP analysis using tshark.

B.2 Discovery

B.2.1 Discovery Waves and Scale

The threat actor's internal reconnaissance occurred in three distinct waves, confirmed independently by both Zeek logs and PCAP analysis. Each wave involved broad SMB and RDP port scanning across the 10.128.239.0/24 subnet, consistent with systematic environment mapping using tools such as SoftPerfect Network Scanner and/or NetExec.

Wave	Date	SMB Connections (Zeek)	SAMR Packets (PCAP)	Unique Targets	Status
1	March 1, 2025 ~23:30 UTC	2,060	967	131	Confirmed
2	March 6, 2025 ~22:50 UTC	5,956	898	125	Confirmed
3	March 8, 2025 ~08:22 UTC	3,023	1,674	134	Confirmed
Total	**March 1–8, 2025**	**14,646**	**3,539**		**All confirmed**

Table B.1: Detailed timeline of events from 01-03-2025 23:25-00:20

Note: PCAP packet counts differ from Zeek entry counts because Zeek logs one entry per SAMR operation, while PCAP captures multiple packets per operation (request, response, and TCP acknowledgements). The chronological scan order did not follow a strictly sequential pattern, which is consistent with parallelised enumeration tools such as NetExec. This activity corresponds to MITRE ATT&CK T1018 (Remote System Discovery) and T1087.002 (Domain Account Discovery).

B.2.2 Active Directory and Directory Enumeration

Zeek dce_rpc logs and PCAP analysis revealed extensive SAMR enumeration from 10.128.239.57 directed at domain controllers, with the WATER domain controller 10.128.239.29 receiving the heaviest enumeration activity. The following SAMR operations were identified:

Operation	Count	Target(s)	MITRE ATT&CK
SamrLookupDomainInSamServer	261	130 unique hosts	T1018 Remote System Discovery
SamrOpenGroup	155	DCs .23, .29 (WATER)	T1069.002 Domain Groups Discovery
SamrGetMembersInGroup	92	DCs .23, .29 (WATER)	T1069.002 Domain Groups Discovery
SamrConnect5 / SamrOpenDomain	Multiple	DCs .23, .29 (WATER)	T1087.002 Domain Account Discovery
NetrLogonSamLogonEx	240,175	DCs .29 (236,198), .23 (3,977)	T1078.002 Valid Accounts: Domain

Table B.2: Detailed timeline of events from 01-03-2025 23:25-00:20

The extensive SamrOpenGroup and SamrGetMembersInGroup operations indicate the threat actor was actively identifying privileged group memberships (e.g., Domain Admins), consistent with pre-escalation reconnaissance. Additionally, LSARPC lookup activity (LsarLookupNames4) was observed against 10.128.239.28, 10.128.239.29, and 10.128.239.30, consistent with account and name resolution during directory-style enumeration.

B.2.3 RDP Port Scanning

PCAP analysis of March 8 traffic using the filter ip.src == 10.128.239.57 && tcp.dstport == 3389 && tcp.flags.syn == 1 revealed 514 RDP SYN packets targeting 153 unique internal hosts. Most hosts received a single SYN probe (port scan), while hosts in the .164–.175, .180, .221–.222, and .225–.226 ranges received 5 SYN retries each, indicating unresponsive hosts that were repeatedly probed. This RDP scanning was not captured in the Zeek logs and represents additional network reconnaissance evidence (MITRE ATT&CK T1018 Remote System Discovery).

B.2.4 Cross-Domain Infrastructure Mapping

Analysis of DNS SRV records, SMB share mappings, and LDAP/Kerberos service queries revealed a multi-domain Active Directory forest. The threat actor's discovery activity extended across multiple named domains, not just a single domain controller.

IP Address	Domain	Hostname	Role	Evidence
10.128.239.20	Root (domain-ees3Ai.local)	jjjjjjjdc1	DC + DNS	DNS SRV, LDAP
10.128.239.21	Root	jjjjjjjdc3	DC + DNS	DNS SRV, Netlogon
10.128.239.22	ADMIN	jjjjjjjaddc5	DC	SMB, SAMR
10.128.239.27	ADMIN	jjjjjjjaddc7	DC	SMB, SAMR

10.128.239.29	WATER	jjjjjjjwtdc23	DC	SMB, SAMR, DCERPC, ADMIN$, SYSVOL, IPC$
10.128.239.23	WATER	jjjjjjjwtdc8	DC	SMB, SAMR, DCERPC
10.128.239.30	PARKS	jjjjjjjpkdc2	DC	DNS, SMB, LSARPC, ADMIN$
10.128.239.31	SAFETY	jjjjjjjsfdc9	DC	SMB mapping

Table B.3: Detailed timeline of events from 01-03-2025 23:25-00:20

B.2.5 Additional Discovery Activity

- **SRVSVC (Server Service Remote Protocol):** Traffic from 10.128.239.57 to 10.128.239.176 using the SRVSVC interface was observed, indicating the threat actor enumerated network shares (MITRE T1135 Network Share Discovery).
- **DCOM Execution:** IOXIDResolver and ISystemActivator traffic from 10.128.239.57 to 10.128.239.32, suggesting DCOM-based remote interaction (MITRE T1021.003 Distributed Component Object Model).
- **DRSUAPI/Active Directory Queries:** The compromised host performed DsBind, DsCrackNames, and DsUnbind against WATER domain DCs (10.128.239.23, 10.128.239.29). These are standard domain-joined computer operations confirming the host was authenticated to the domain.
- **NetrShareEnum:** 274 share enumeration requests observed across multiple hosts, providing the threat actor with a map of available network file shares.

B.3 Lateral Movement

B.3.1 Administrative Share Access (ADMIN$)

A significant finding is direct evidence that the beachhead host 10.128.239.57 accessed the ADMIN$ administrative share on multiple domain controllers:

- \\10.128.239.28\ADMIN$ (POWER domain DC)
- \\10.128.239.29\ADMIN$ (WATER domain DC)
- \\10.128.239.30\ADMIN$ (PARKS domain DC)

Access to ADMIN$ requires administrative-level credentials and constitutes one of the strongest indicators of authenticated lateral movement observed in the network evidence. This demonstrates that the threat actor possessed and exercised domain administrator privileges to access the Windows system directory on remote domain controllers.

B.3.2 Movement into WATER Domain Infrastructure

Repeated Netlogon/DCERPC activity from 10.128.239.57 to 10.128.239.29 supports sustained interaction with core domain-authentication services on the WATER domain. Additionally, direct SMB access to named WATER domain resources was observed:

- \\jjjjjjjwtDC23.water.domain-ees3Ai.local\SYSVOL

- \\jjjjjjjwtDC23.water.domain-ees3Ai.local\IPC$

Access to SYSVOL is particularly notable, as this share contains Group Policy Objects (GPOs) and login scripts. Browsing SYSVOL may indicate the threat actor was reviewing domain policies or preparing for policy-based payload deployment.

B.3.3 Interactive RDP Sessions

Zeek SSL and connection logs identified interactive RDP sessions from 10.128.239.57 to six internal hosts:

Destination IP	Protocols Observed	Inferred Role
10.128.239.34	RDP, RDPUDP, RDPUDP2, TLSv1.2	File server
10.128.239.35	RDP, RDPUDP, RDPUDP2, TLSv1.2	File server
10.128.239.36	RDP, RDPUDP, RDPUDP2, TLSv1.2	File server
10.128.239.37	RDP, RDPUDP, RDPUDP2, TLSv1.2	File server
10.128.239.39	RDP, RDPUDP, RDPUDP2, TLSv1.2	Server
10.128.239.176	RDP, SRVSVC, TLSv1.2	Server (share enumeration)

Table B.4: Detailed timeline of events from 01-03-2025 23:25-00:20

These interactive RDP sessions provided the threat actor with hands-on-keyboard access to file servers and infrastructure hosts, complementing the administrative SMB-based movement observed via ADMIN$ access (MITRE ATT&CK T1021.001 Remote Desktop Protocol).

B.4 Interpretation

The evidence supports a progression from broad network discovery into targeted, authenticated lateral movement across the Active Directory forest.

The threat actor used 10.128.239.57 as the beachhead host following RDP access with valid, pre-compromised credentials. From this single host, they conducted broad discovery across the environment in three waves (March 1, 6, and 8), encompassing SMB and RDP port scanning of 153 unique hosts, SAMR enumeration of approximately 130 hosts, LSARPC name lookups, and Netlogon interaction with domain-authentication infrastructure.

The threat actor then moved beyond reconnaissance into authenticated lateral movement, evidenced by ADMIN$ access to domain controllers at 10.128.239.28 (POWER), 10.128.239.29 (WATER), and 10.128.239.30 (PARKS). This was accompanied by repeated Netlogon interaction with the WATER domain controller and direct access to WATER-side SMB resources including SYSVOL and IPC$. Interactive RDP sessions to six additional hosts (.34, .35, .36, .37, .39, .176) provided hands-on access to file servers and infrastructure systems.

The cross-domain infrastructure mapping reveals that the threat actor’s activity reached named infrastructure associated with POWER (.28), WATER (.29), PARKS (.30), and SAFETY (.31). This characterises the movement pattern as cross-domain lateral movement within the AD forest, rather than simple movement within a single subnet.

Note on account creation: No SamrCreateUser2InDomain or SamrAddMemberToGroup operations were detected in either the Zeek logs or PCAP files. This was verified using the tshark filter samr.opnum == 12 || samr.opnum == 22 || samr.opnum == 37 across all March 1 PCAPs, returning zero results. Reference case literature (DFIR Report, December 2025) indicates that in comparable Lynx ransomware intrusions, account creation was performed locally on the domain controller via the Active Directory Users and Computers snap-in (dsa.msc) during an interactive RDP session. Such operations occur internally on the DC host and do not traverse the network, making them invisible to network sensors. The endpoint event logs (Security Event IDs 4720/4728) that would capture such activity were unavailable, as the IT team's emergency power-down destroyed volatile host artifacts. The extensive group enumeration observed (155 SamrOpenGroup and 92 SamrGetMembersInGroup operations) represents the network-visible precursor to such account manipulation.

B.5 MITRE ATT&CK Mapping

Technique ID	Technique Name	Evidence
T1078	Valid Accounts	Pre-compromised credentials used for RDP and SMB access
T1046	Network Service Discovery	SMB port 445 scanning of 153 hosts, RDP port 3389 scanning
T1018	Remote System Discovery	RDP SYN probing (514 packets), NetScan/NetExec enumeration
T1087.002	Domain Account Discovery	SAMR enumeration (SamrLookupDomainInSamServer)
T1069.002	Domain Groups Discovery	SamrOpenGroup (155), SamrGetMembersInGroup (92)
T1135	Network Share Discovery	SRVSVC enumeration, NetrShareEnum (274 requests)
T1021.001	Remote Desktop Protocol	Interactive RDP sessions to 6 internal hosts
T1021.002	SMB/Windows Admin Shares	ADMIN$ access to DCs .28, .29, .30
T1021.003	Distributed Component Object Model	IOXIDResolver/ISystemActivator to .32
T1219	Remote Access Software	AnyDesk installed on DC (not used subsequently)

Table B.5: Detailed timeline of events from 01-03-2025 23:25-00:20

C. Data Exfiltration (Double Extortion)

C.1 Overview

Investigation of the merged PCAP dataset confirmed that compromised host 10.128.239.57 orchestrated a large-scale data exfiltration operation to external server temp.sh (51.91.79.17) on March 6, 2025. Analysis of TCP conversation statistics revealed 1,082,867,712 bytes (1,033 MB) uploaded over TLS 1.3 encrypted connections.

The exfiltration methodology followed a multi-stage process. First, the attacker conducted internal data collection from file server 10.128.239.37 via SMB protocol, with 27,305 total file access operations documented. Second, collected data was compressed into .7z and .zip archive formats on the file server. Third, compressed archives were staged on the compromised workstation 10.128.239.57 through internal SMB file transfers. Finally, staged archives were uploaded to temp.sh infrastructure over HTTPS port 443 using TLS 1.3 encryption.

Because all external uploads employed TLS 1.3 encryption, direct inspection of payload contents was not possible. However, convergent evidence from multiple independent sources establishes the exfiltration chain with high confidence. This evidence includes SMB filename metadata revealing specific files accessed, DNS resolution logs showing persistent queries for temp.sh domain, TLS Server Name Indication fields confirming encrypted connections to the exfiltration server, and TCP volume statistics demonstrating large asymmetric data uploads. The observed tactics align with known Lynx ransomware group double-extortion operations.

C.2 Network Infrastructure Identification

Network traffic analysis identified the primary exfiltration infrastructure:

Entity / IP	Role
10.128.239.57	Compromised workstation: sole internal host communicating with temp.sh; served as upload relay
10.128.239.37	Internal file server: data collection source; performed archive compression
51.91.79.17	External exfiltration server: resolved from temp.sh domain
temp.sh	File-sharing service domain: attacker-controlled infrastructure

Table C.1: Primary network entities in the exfiltration chain.

C.3 DNS Resolution Evidence

DNS query analysis confirmed persistent resolution of the temp.sh domain to IP address 51.91.79.17. Total DNS queries for temp.sh observed: 47 queries. Multiple queries originated directly from compromised host 10.128.239.57, establishing clear intent to connect to the exfiltration infrastructure.

C.4 TLS Connection Evidence

TLS handshake analysis confirmed 11 distinct TLS 1.3 ClientHello sessions with Server Name Indication field set to "temp.sh", all originating from compromised workstation 10.128.239.57 to destination server 51.91.79.17. All sessions employed TLS version 1.3 over HTTPS port 443.

The exclusive use of TLS 1.3 prevented direct payload inspection. Archive file contents, filenames within compressed archives, and specific data fields being transferred cannot be directly observed in captured network traffic. The presence of .7z and .zip strings in certain packets likely reflects HTTP form field names or metadata headers visible prior to full payload encryption, not the archive contents themselves.

C.5 Data Volume Analysis

TCP conversation statistics quantified the total data exchanged between compromised host 10.128.239.57 (A) and exfiltration server 51.91.79.17 (B):

Metric	Value
Source (Address A)	10.128.239.57
Destination (Address B)	51.91.79.17 (temp.sh)
Packets Outbound (A→B)	684,911
Bytes Outbound (A→B)	1033MB (1.033GB)
Packets Inbound (B→A)	269,030
Bytes Inbound (B→A)	15 MB
Total Packets	953,941
Total Bytes	1,048 MB (1.048GB)
Protocol	TLS 1.3 / HTTPS (port 443)

Table C.2: TCP conversation statistics for primary exfiltration flow.

.

C.6 Compromised Data Identification

C.6.1 File Access Scale

SMB protocol analysis documented 27,305 total file access events involving compromised host 10.128.239.57. This volume represents mass automated data collection characteristic of ransomware exfiltration scripts.

C.6.2 Critical Compromised Files

The following critical files were identified through SMB metadata analysis, organized by category:

Credentials	
user_db_export.json	Full PII per record: name, SSN, DOB, sex, job, company, address, email, blood group, username, GPS coordinates
credit_card_transactions_2024.csv	Card transactions: cardholder name, address, email, DOB, card provider, full card number, expiry date, CVV
NTUSER.DAT	File content not provided; description unavailable

Table C.3: Credentials files

Domain Controller Backups	
DC1.domain-ees3Ai.localD2025-03-06T220038_D2A6.vib	File content not provided; description unavailable
DC3.domain-ees3Ai.localD2025-03-06T220038_A818.vib	File content not provided; description unavailable
DC7.admin.domain-ees3Ai.localD2024-07-21T220053_A9C8.vib	File content not provided; description unavailable

Table C.4: Domain Controller Backups files.

VM Backups	
WIN712.safety.domain-ees3Ai.IoD2024-07-20T220551_EB51.vbk	File content not provided; description unavailable
WIN919.safety.domain-ees3Ai.vbm	File content not provided; description unavailable
WIN962.safety.domain-ees3Ai.vbm	File content not provided; description unavailable

Table C.5: VM Backup files

Group Policy	
Groups.xml	6 GPO files, each targeting a different sub-domain, all using action=Update on the built-in Administrators group (S-1-5-32-544). Five files add a domain-specific server_admins group as a member: WATER\server_admins , SAFETY\server_admins, PARKS\server_admins , ADMIN\server_admins, and domain-ees3Ai\server_admins. A sixth file targets the Remote Desktop Users group (S-1-5-32-555) and adds domain-ees3Ai\Domain Users as a member, granting all domain users remote desktop access across the domain.
Registry.xml	19 GPO files across all sub-domains (WATER, SAFETY, PARKS, ADMIN, domain-ees3Ai) containing three distinct registry policy types. (1) TamperProtection (5 files): sets HKLM\SOFTWARE\Microsoft\Windows Defender\Features\TamperProtection to REG_DWORD value 4. Applied with a run-once filter, meaning the policy executes only on first application. Present across water, safety, parks, admin, and domain-ees3Ai sub-domains. (2) Sysmon Log Size (9 files): sets MaxSize under HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\WINEVT\Channels\Microsoft-Windows-Sysmon/Operational to REG_DWORD value 0xFFFFFFFF. Applied across all sub-domains including both domainaaaaaTW and domain-ees3Ai variants. (3) Timezone (5 files): sets multiple values under HKLM\SYSTEM\CurrentControlSet\Control\TimeZoneInformation, including TimeZoneKeyName=UTC and Bias, ActiveTimeBias, DaylightBias, StandardBias all set to 0x00000000. Applied across water, safety, parks, admin, and domain-ees3Ai sub-domains.

Table C.6: Group Policy files

Law Enforcement	
arrestees.zip	File content not provided; description unavailable
offenders.zip	File content not provided; description unavailable

clearances.zip	File content not provided; description unavailable
incidents.zip	File content not provided; description unavailable
victims.zip	FBI NIBRS 2022 aggregate statistics: 13.8M victims across crimes against persons, property, and society by offense category

Table C.7: Law Enforcement files

Audit	
audit.csv	Windows audit policy configuration: subcategory GUIDs and success/failure inclusion settings (e.g. Credential Validation, Kerberos Authentication)
Amcache.hve	File content not provided; description unavailable

Table C.8: Audit files

Threat Intel	
mandiant-apt1-report.pdf	File content not provided; description unavailable
APT27+turns+to+ransomware.pdf	File content not provided; description unavailable
apt41-recent-activity.pdf	File content not provided; description unavailable

Table C.9: Threat Intel files

Backup Config	
VeeamConfigBackup	File content not provided; description unavailable

Table C.10: Backup Config files

C.7 Archive Compression and Staging

Network traffic analysis revealed archive files (.7z and .zip formats) were compressed on file server 10.128.239.37 and transferred to compromised workstation 10.128.239.57 via SMB before external upload. The following compressed archive files were identified:

Law Enforcement / Criminal Justice Data
arrestees.zip
offenders.zip
victims.zip
incidents.zip
clearances.zip
circumstances.zip
completed.zip
participation.zip
relationships.zip

drugInvolvement.zip
weaponForce.zip
timeOfDay.zip
state.zip
stateTables.zip
fedTables.zip
location.zip
methodology.zip

Table C.11: Law enforcement compressed archive files (17 files).

Geographic Information Systems (GIS) Data
domainaaaaa_Schools_R-12.zip
domainaaaaa_Zoning.zip
City_Limits.zip
Fire_Districts.zip
FEMA_Base_Flood_Elevations.zip
MO_2013_Outstanding_Resource_Waters_Marshes-shp.zip
MO_2017_National_Register_Sites-shp.zip
MO_2019_Missouri_Dept_of_Conservation_Managed_Public_Waterbodies-shp.zip
MO_NPDES_Animal_Feeding_Operations.zip
Neighborhood_Service_Areas.zip
Street_Centerline.zip

Table C.12: GIS compressed archive files (11 files).

The staging process allowed the attacker to compress large datasets on the file server, transfer archives internally via SMB without consuming external bandwidth, and upload from a single relay host to simplify command-and-control communications. Following internal staging, compressed archives were uploaded to temp.sh over TLS 1.3 encrypted connections.

C.8 Encryption and Analytical Limitations

All external traffic to temp.sh employed TLS 1.3 encryption exclusively. This prevented direct inspection of archive contents, individual filenames within archives, and actual data payloads. However, convergent evidence establishes exfiltration with high confidence:

Evidence Type	Finding
SMB Metadata	27,305 file accesses including DC backups, credentials, financial data, law enforcement records
Archive Staging	28 compressed .zip archives transferred from file server to workstation via SMB
DNS Queries	47 queries for temp.sh domain
TLS Sessions	11 confirmed encrypted HTTPS connections with SNI verification
Traffic Volume	1,033 MB asymmetric outbound vs. 15 MB inbound

Table C.13: Convergent evidence supporting exfiltration conclusion.

This multi-source evidence demonstrates sophisticated data exfiltration consistent with Lynx ransomware double-extortion methodology. While encryption prevents direct payload observation, the circumstantial chain establishes the exfiltration narrative with investigative confidence suitable for incident response decision-making.

D. Payload Deployment

D.1 Overview

Our investigation revealed that the attacker deployed ransomware across the internal network through a coordinated approach involving lateral movement, remote execution, and administrative access. We believe that the initial ransomware payload was dropped into the internal network through an RDP connection to Patient Zero (10.128.239.57). Patient Zero was then used as a staging point to distribute the ransomware payload across the internal network via SMB. We identified multiple suspected payloads through deep packet inspection of the PCAP files.

Following the RDP session, the attacker leveraged multiple techniques, including SMB-based file transfers and RDP sessions to propagate and execute the payload across multiple systems. This combination of techniques suggests both automated deployment and manual attacker involvement.

D.2 How the Payload was Deployed

We strongly believe that the payload was dropped into the internal network via an RDP session to Patient Zero. However, as RDP sessions are encrypted, we are unable to access each RDP session to determine when exactly the payload was dropped into the network.

The payload deployment was carried out from the compromised host 10.128.239.57, which was the attacker's internal pivot and distribution node. Based on the network evidence, the attacker first validated remote write access across the environment, then staged or transferred suspicious executables over SMB and likely used RDP for manual execution on selected servers. This staging role is further supported by a prolonged inbound RDP session to 10.128.239.57 on 2025-03-08 at 03:21:04Z, lasting approximately 67 minutes, indicating sustained interactive attacker control during the later deployment phase.

The earliest payload related behaviour was the repeated creation and deletion of a 0 byte file called delete.me over SMB and from the Zeek dataset, delete.me was observed over 135 unique destination hosts, with 133 on 2025-03-01, 134 on 2025-03-06 and 131 on 2025-03-08. Where the remote share path is visible, delete.me appeared over ADMIN$ on 62 hosts and over

C$ on 43 hosts, with some hosts showing both. This is suspected to be administrative share write testing or access validation instead of the ransomware payload.

Date (UTC)	Total Events	Unique Destination Hosts	Notes
2025-03-01	449	133	Earliest observed delete.me wave which signalled write / access testing
2025-03-06	526	134	Largest admin share testing wave
2025-03-08	504	131	Later validation wave
Total	1479	135	741 SMB::FILE_OPEN, 738 SMB::FILE_DELETE

Table D.1: Summary of SMB waves over the three days.

Share Path	Unique Hosts	Interpretation
ADMIN$	62	Evidence of administrative share write testing
C$	43	Privileged file access / validation

Table D.2: Count of unique hosts accessed by administrative share.

The earliest executable transfer phase happened on 2025-03-06, where Suricata recorded repeated ET INFO SMB2 NT Create AndX request For an Executable File alerts from 10.128.239.57 to multiple systems, with the first wave targeting 10.128.239.36 between the time of 23:05:50Z to 23:06:23Z. The next wave targeted 10.128.239.34 between 23:12:12Z to 23:12:38Z, with the largest wave targeting 10.128.239.37 starting at 23:13:49Z and increasing afterwards exponentially. These repeated executable related SMB alerts are consistent with staged lateral tool transfer from the compromised pivot to selected internal systems.

During this March 6 deployment window, packet analysis revealed the most suspicious payload related filenames, where 10.128.239.98 returned an SMB Find Response to 10.128.239.57 containing root level entries which consisted of hfs.exe, hfs.ips.txt and kkwlo.exe, which is the earliest clean packet level appearance of the strongest suspicious executable candidate, kkwlo.exe. Zeek also showed 10.128.239.57 opening \\10.128.239.34\software\hfs.exe at 2025-03-06 23:12:38Z which suggests that hfs.exe could be a staging or transferring tool instead of the final encryptor. Another suspicious executable, Microsofts.exe, also appeared in a later SMB directory entry in the PCAP files, which makes it a strong secondary payload candidate.

The final encryption phase however was most likely done through interactive RDP sessions instead of just automated SMB as although the March 6 SMB waves from 10.128.239.57 show clear staging and transfer of suspicious executables to internal systems, the network-only dataset does not conclusively reveal the final executed ransomware filename, but at the same time, 10.128.239.57 established internal RDP sessions to multiple servers, including 10.128.239.34, 10.128.239.35, 10.128.239.36, 10.128.239.37, 10.128.239.39 and 10.128.239.176, which leads to our conclusion that SMB was used to prepare and stage tooling, while the final encryption was manually launched on selected systems through RDP, which

explains why the exact final payload was not directly recoverable from the supplied Zeek, Suricata and PCAP artefacts.

D3 Reconnaissance before Payload Deployment

During early stage activity on 2025-03-01, we identified the presence of a ransom note file “HOW TO BACK FILES.txt” after scraping the PCAP files for readable UTF-16 strings. This file was discovered in SMB traffic as part of directory listings, indicating that it was already present on the host. However the fact that the attacker was able to enumerate and access this file through SMB suggests that they have successfully gained the rights to browse and interact with files on internal hosts. This reconnaissance activity allowed the attacker to verify their file-level access and explore available directories before deploying the payload.

We further observed that Patient Zero accessed the backup key through the LSASS pipe over SMB in Zeek logs as shown below:

Timestamp	Destination IP	DCE_RPC Operation	DCE_RPC Named Pipe	DCE_RPC Endpoint
2025-03-06T22:41:51.038Z	10.128.239.23	bkrp_BackupKey	\pipe\lsass	BackupKey

Table D.3: Zeek log showing access to backup key.

The \pipe\lsass connects to the Local Security Authority Subsystem Service pipe over SMB. This particular RPC interface is used to extract DPAPI backup keys or perform domain controller backup key operations. This maps to MITRE ATT&CK T1003 - Credential Access.

Shortly after this, the attacker utilized SMB to open multiple backup files on 10.128.239.39, 10.128.239.36, and 10.128.239.35 as shown below:

Timestamps	Destination IP	File Names
2025-03-06T23:04:53.337Z to 2025-03-06T23:05:33.386Z	10.128.239.39	Backup\files Backup\extra\jjjjjjjWIN712.safety.domain-ees3Ai.local Backup\extra\zip Backup\Server1\jjjjjjjsfdc9 Backup\important\jjjjjjjWIN962.safety.domain-ees3Ai.local Backup\work Backup\DCs\jjjjjjjsfdc6 Backup\VeeamConfigBackup\jjjjjjjBACKUP04 Backup\important\jjjjjjjWIN919.safety.domain-ees3Ai.local
2025-03-06T23:05:55.838Z to 2025-03-06T23:06:08.416Z	10.128.239.36	Backup\dc\jjjjjjjDC1.domain-ees3Ai.local Backup\dc\jjjjjjjDC3.domain-ees3Ai.local Backup\VeeamConfigBackup\jjjjjjjBACKUP01
2025-03-06T23:06:40.594Z to 2025-03-06T23:13:	10.128.239.35	Backup\adf\jjjjjjjADF04.admin.domain-ees3Ai.local Backup\dc4\jjjjjjjadDC7.admin.domain-ees3Ai.local

44.752Z		

Table D.4: Backup files accessed by Patient Zero through SMB.

We observed a suspicious RDP connection to Patient Zero on March 8 at 03:21:04. The RDP connection lasted a total of approximately 1.12 hours, suggesting an interactive RDP session.

Timestamp	Source IP	Duration	Details
2025-03-08T08:21:04.386Z	77.90.153.30	~67 minutes and 35 seconds	~24.7MB received by Patient Zero, ~4.9MB sent from Patient Zero

Table D.5: Zeek log showing the interactive RDP session.

Shortly after the attacker established the RDP connection on 8 March, there were numerous SMB:: FILE OPEN and SMB:: FILE DELETE actions involving the file “delete.me” originating from Patient Zero. Given that these actions were performed in a short span of time, it is highly suspected that the attacker is running a script to confirm that they have WRITE/MODIFY permissions on the various targets. Some of the logs are shown below:

Timestamp	Destination IP	Action
2025-03-08T08:22:04.126Z	10.128.239.21	SMB::FILE_OPEN
2025-03-08T08:22:04.126Z	10.128.239.21	SMB::FILE_DELETE
2025-03-08T08:22:04.149Z	10.128.239.65	SMB::FILE_OPEN
2025-03-08T08:22:04.149Z	10.128.239.65	SMB::FILE_DELETE
2025-03-08T08:22:04.566Z	10.128.239.28	SMB::FILE_OPEN
2025-03-08T08:22:04.566Z	10.128.239.28	SMB::FILE_DELETE

Table D.6: Examples of Zeek logs with rapid SMB operations.

In the same RDP session, we noted some interesting logs:

Timestamp	Destination IP	Action	File Name
2025-03-08T09:06:19.788Z	10.128.239.66	SMB::FILE_OPEN	UninstallWinClient.exe
2025-03-08T09:06:32.458Z	10.128.239.47	SMB::FILE_OPEN	Program Files\desktop.ini
2025-03-08T09:06:32.463Z	10.128.239.47	SMB::FILE_OPEN	Users\desktop.ini
2025-03-08T09:06:34.063Z	10.128.239.47	SMB::FILE_OPEN	Program Files (x86)
2025-03-08T09:06:34.074Z	10.128.239.47	SMB::FILE_OPEN	Program Files (x86)\Common Files
2025-03-08T09:06:34.084Z	10.128.239.47	SMB::FILE_OPEN	Program Files

			(x86)\Common Files\Microsoft Shared

Table D.7: Zeek logs showing Patient Zero accessing various program files after opening a software.

After opening UninstallWinClient.exe, the attacker iterated through numerous Program Files on 10.128.239.47. We believe that the UninstallWinClient.exe could have been an uninstaller for some security software to disable endpoint protection. This maps to MITRE ATT&CK: T1562.001 - Disable or Modify Tools.

D4 Payload Transfer

There was a coordinated SMB wave from Patient Zero on 2025-03-08. This further supports the conclusion that 10.128.239.57 was the attacker's main internal pivot used to distribute tooling and deploy the ransomware across other systems. The repeated return to SMB-based activity from the same source host suggests deliberate operator control and staged deployment rather than a single isolated transfer event.

Figure D.1: Screenshot of TCP stream 41119 in 6 March PCAP file.

Further analysis of PCAP data on 2025-03-06 revealed the additional suspicious payload-related filenames, including:

- kkwlo.exe
- hfs.exe

- hfs.ips.txt

These filenames were identified by scraping readable strings from raw PCAP data during the 6 March SMB deployment period. Although the full binaries could not be extracted from the traffic, the presence of these unusual executable and support-file names in SMB-related traffic is highly suspicious. They are not typical Windows system files, and their appearance during a period of intense lateral SMB activity strongly suggests that they were part of the attacker's deployment toolkit or ransomware payload set. In particular, the presence of both executable files and an accompanying text file suggests that the attacker may have been transferring not only payload binaries, but also supporting configuration or targeting information used during execution.

Taken together, these findings indicate that payload transfer was carried out through SMB-based lateral tool transfer, with 10.128.239.57 pushing suspicious executables to internal systems using administrative shares. This behaviour is consistent with MITRE ATT&CK T1570 - Lateral Tool Transfer, where adversaries move malicious tools or payloads from one compromised system to another in preparation for execution.

D5 Impact (Final Encryption)

The ransomware deployment affected multiple systems across the internal network, including both host endpoints and critical infrastructure components.The exact time of the final file encryption could not be observed from just the network traffic alone, but the evidence we have gathered strongly indicates that the attacker progressed from staging and access validation to impact on selected internal systems, with the strongest evidence suggesting that the final encryption phase was most likely executed manually though a interactive RDP session after tooling had been staged using SMB from 10.128.239.57. This behaviour is consistent with MITRE ATT&CK T1486 - Data Encrypted for Impact, where adversaries execute ransomware to encrypt files across compromised systems.

The deployment activity affected multiple systems, most likely those that were targeted by the executable related SMB activity and later accessed through RDP. The network evidence provides different confidence levels for different hosts, with 10.128.239.57 initiating RDP sessions to 10.128.239.34, 10.128.239.35, 10.128.239.36, 10.128.239.37, 10.128.239.39 and 10.128.239.176, which is consistent with manual operator access during later stages of the intrusion. Executable related SMB activity could also be seen from 10.128.239.57 to 10.128.239.34, 10.128.239.36, 10.128.239.37 and 10.128.239.66, which shows that these systems were also part of the affected systems. 10.128.239.98 also exposed the suspicious file cluster of kkwlo.exe, hfs.exe and hfs.ips.txt in SMB directory data.

Furthermore, backup related infrastructure could have also been impacted, with evidence of the attacker invoking bkrp_BackupKey against 10.128.239.23 along with multiple backup hosts and Veeam related artefacts being visible in the PCAP files.

However, since no endpoint telemetry or disk evidence was provided, the network traffic alone was insufficient to allow us to conclusively identify every encrypted host or recover the exact final ransomware executable.

MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1133	External Remote Services	Exposed RDP/3389 on 10.128.239.57 allowed direct inbound access from 195.211.190.189
Initial Access	T1078.002	Valid Accounts: Domain Accounts	Pre-compromised credentials for lgallegos used for immediate Kerberos AS and NTLM authentication
Lateral Movement	T1021.001	Remote Desktop Protocol	Interactive RDP sessions from .57 to 6 internal hosts (.34, .35, .36, .37, .39, .176)
Lateral Movement	T1021.002	SMB/Windows Admin Shares	ADMIN$ access to DCs at .28 (POWER), .29 (WATER), .30 (PARKS); delete.me write testing across 135 hosts
Lateral Movement	T1021.003	Distributed Component Object Model	IOXIDResolver and ISystemActivator traffic from .57 to .32
Lateral Movement	T1570	Lateral Tool Transfer	SMB transfer of kkwlo.exe, hfs.exe, Microsofts.exe from .57 to internal hosts on March 6
Discovery	T1046	Network Service Discovery	SMB port 445 scanning of 153 hosts; RDP port 3389 SYN scanning (514 packets on March 8)
Discovery	T1018	Remote System Discovery	Three enumeration waves (Mar 1, 6, 8) totalling 14,646 SMB connections and 3,539 SAMR packets
Discovery	T1087.002	Domain Account Discovery	SAMR enumeration (SamrLookupDomainInSamServer, SamrConnect5, SamrOpenDomain) against WATER DCs
Discovery	T1069.002	Domain Groups Discovery	155 SamrOpenGroup and 92 SamrGetMembersInGroup operations targeting privileged group memberships
Discovery	T1135	Network Share Discovery	SRVSVC enumeration and 274 NetrShareEnum requests mapping available file shares
Collection	T1039	Data from Network Shared Drive	27,305 SMB file access events on file server .37 including DC

			backups, credentials, financial data, and law enforcement PII
Exfiltration	T1567	Exfiltration Over Web Service	1,033 MB uploaded to temp.sh (51.91.79.17) over 11 TLS 1.3 sessions; 47 DNS queries for temp.sh
Exfiltration	T1560	Archive Collected Data	28 .7z/.zip archives compressed on file server .37 and staged on .57 before external upload
Defense Evasion	T1562.001	Disable or Modify Tools	UninstallWinClient.exe on .66; GPO TamperProtection disabled via Registry.xml across all sub-domains
Credential Access	T1003	OS Credential Dumping	bkrp_BackupKey invoked via \pipe\lsass on DC .23 to extract DPAPI backup keys
Impact	T1486	Data Encrypted for Impact	Ransomware deployed via RDP after SMB staging

Conclusion and Recommendations

RECOMMENDATIONS
Critical Immediate Action Required (48-72 Hours)

#	Recommendation Title	Business Risk	Technical Description	MITRE ATT&CK Mitigation
C1	Immediate Credential Reset and Session Invalidation	If the attacker still holds working credentials or tokens, they may return even after containment work appears complete.	Reset all active domain user passwords in waves within 72 hours. Prioritize Tier 0 admins, server admins, service accounts, remote access users, and any account with local admin rights. Invalidate all active VPN, RDP, SSO, refresh-token, and privileged sessions. Review AD for unauthorized account creation, group changes, and newly assigned remote logon rights. Rotate service-account credentials and migrate eligible service accounts to gMSA.	M1018, M1027
C2	Remove Direct RDP Exposure from the Internet	A directly exposed RDP service gives threat actors a standing doorway into the business and materially increases ransomware risk.	Remove all internet NAT/port-forwarding rules to 3389/tcp. Block inbound RDP at the perimeter firewall. If RDP remains necessary, require access only through a managed control point such as a hardened VPN with MFA, an RD Gateway, or a PAM/jump-host platform. Restrict source IPs where feasible and enable session recording for administrative RDP.	M1035
C3	Block Known File-Sharing and	The attacker exfiltrated 1,033 MB of sensitive data	Implement DNS-layer and proxy-layer blocking of known file-sharing and paste services (temp.sh, transfer.sh, file.io, mega.nz, anonfiles, etc.). Deploy a web proxy or CASB with TLS	M1031, M1037

	Exfiltration Services at the Perimeter	to temp.sh without any perimeter controls blocking or alerting on this traffic.	inspection capability to detect uploads to uncategorised or newly registered domains. Create firewall alerts for any internal host uploading more than 100 MB to a single external IP within a 24-hour window.	
C4	Restrict Administrative Share Access on Domain Controllers	Unrestricted ADMIN$ and C$ access allowed the attacker to validate write permissions across 135 hosts and pivot to DCs in POWER, WATER, and PARKS domains.	Disable default administrative shares (ADMIN$, C$) on all domain controllers and critical servers via GPO. Where admin share access is operationally required, restrict it to designated PAWs through host-based firewall rules. Monitor for anomalous SMB connections to administrative shares using Windows Security Event ID 5140/5145.	M1035, M1030

High Priority Short Term (1-2 Weeks)

#	Recommendation Title	Business Risk	Technical Description	MITRE ATT&CK Mitigation
H1	Harden Any Retained VPN or Remote Access Platform	Even if direct RDP is removed, a weak VPN or access gateway can become the next single-point-of-failure.	For any VPN, RD Gateway, or ZTNA service left in production, enforce IP allowlisting or geo-restrictions where business operations permit; require device certificates or mutual TLS for managed endpoints; enable detailed success/failure logs; alert on unusual geography, new device, or repeated failures; and patch the appliance or gateway to current vendor firmware. If Apex has no VPN today, apply these controls to whatever remote access service replaces direct RDP.	M1035, M1051

H2	Segment the Remote Access Landing Zone from Core Systems	Without segmentation, one compromised remote-access host can reach servers, domain controllers, and backups in minutes.	Place all remote access termination points into a dedicated management or access zone. Explicitly deny SMB, RPC, WinRM, RDP, and backup protocols from that zone to domain controllers, hypervisors, and backup infrastructure unless a documented business path exists. Implement deny-by-default east-west firewall rules and only open narrowly scoped admin paths through a jump server.	M1030
H3	Implement Privileged Access Management for Administrative Remote Access	If standard or shared accounts can RDP to servers directly, one stolen account can escalate into broad operational impact.	Separate admin identities from normal user identities. Adopt a tiered model: Tier 0 for domain/identity systems, Tier 1 for servers, Tier 2 for workstations. Prohibit VPN and remote-access users from directly administering servers unless approved through a PAM or jump-host workflow. Vault privileged passwords, rotate them automatically, and record high-risk sessions.	M1026
H4	Implement Offline and Immutable Backups	Without secure backups, the affected company will face prolonged operational	Implement a 3-2-1 backup strategy with at least one copy stored offline or in an immutable format. These backups should be of write-once-read-many (WORM) format and protected against modification or deletion. The backups should also be segregated from the main network and inaccessible via standard administrative	M1053

		downtime, potential financial losses, reputational damage, and increased likelihood of paying the ransom fee.	credentials. Access to these backups need to be strictly controlled and monitored to detect any unauthorized access attempts.	
H5	Enforce East-West Network Segmentation for SMB and RDP	The attacker conducted unrestricted SMB scanning across 153 hosts and RDP port scanning from a single beachhead, indicating no lateral traffic controls were in place.	Implement microsegmentation or host-based firewall policies to restrict SMB (445/tcp) and RDP (3389/tcp) traffic between workstations and between workstation and server segments. Only permit these protocols from authorised jump servers or PAWs to designated target hosts. Deploy Zeek or Suricata on internal SPAN ports to detect lateral scanning patterns.	M1030, M1035
H6	Limit SAMR and LSARPC Enumeration from Non-DC Hosts	The threat actor performed over 1,444 SAMR operations and LSARPC lookups from a compromised workstation, mapping privileged groups and user accounts across the entire AD	Apply the SAM-R remote access restriction GPO (Network access: Restrict clients allowed to make remote calls to SAM) to limit SAMR queries to authorised admin accounts only. Configure Windows Firewall rules to block DCE/RPC traffic from workstation-tier hosts to DCs except for domain-join and authentication traffic.	M1026, M1030

		forest without detection.		
H7	Enforce Least-Privilege Access to Sensitive File Shares	A single compromised workstation accessed 27,305 files on the internal file server including DC backups, credential databases, credit card records, and law enforcement PII, indicating excessive share permissions.	Conduct an immediate audit of all file share ACLs on servers .34-.37 and .39. Remove broad read/write permissions and replace with role-based access groups. Segregate high-sensitivity data into restricted shares requiring explicit approval. Enable file access auditing (Event ID 4663).	M1026, M1022

Medium Priority Medium Term (1-3 Months)

#	Recommendation Title	Business Risk	Technical Description	MITRE ATT&CK Mitigation
M1	Deploy Minimum Viable Network and Authentication Monitoring	Without monitoring, Apex may not detect another intrusion until business systems are already impacted.	Stand up a practical monitoring stack: Zeek and Suricata on a SPAN/TAP, Windows event forwarding from domain controllers and key servers, and a SIEM or managed log platform. Build detections for external RDP attempts, successful remote logons outside business hours, risky geography, repeated VPN failures, successful remote logon followed by Kerberos/NTLM from a new host, and scan-like behavior within 15 minutes of remote access.	M1047

M2	Strengthen Credential Hygiene and External Credential Exposure Monitoring	If employees reuse passwords or choose breached passwords, valid-account attacks will remain likely.	Enforce 16+ character passwords or passphrases, block known-breached passwords using NIST-aligned screening, require an enterprise password manager, review all accounts with remote access privileges quarterly, and subscribe to credential leak monitoring for corporate email domains. Require immediate reset and investigation when corporate credentials appear in breach data.	M1027
M3	Redesign Backup Access and Resilience	If backups remain reachable from the same trust zone as production systems, a future ransomware event can remove the company's recovery path.	Move backups onto a segregated management plane with separate credentials and no direct interactive access from standard admin workstations. Adopt immutable or offline copies, enforce the 3-2-1 model, restrict who can delete or encrypt backups, and test restoration quarterly with documented recovery time objectives.	M1053
M4	Deploy Network-Based DLP and Traffic Anomaly Detection	The highly asymmetric traffic pattern (1,033 MB outbound vs 15 MB inbound) to a single external IP went undetected, indicating no DLP or traffic anomaly monitoring was in place.	Deploy network DLP sensors at egress points to inspect outbound traffic for sensitive data patterns (SSN formats, credit card numbers, PII fields). Implement NetFlow or Zeek-based anomaly detection to flag unusual outbound data volumes. Configure alerts for any workstation-tier host initiating HTTPS connections to external IPs with cumulative upload volume exceeding baseline thresholds.	M1057, M1031
M5	Audit and Restrict SYSVOL	Direct SMB access to SYSVOL on the WATER DC was	Restrict SYSVOL write access to Tier 0 administrators only. Enable Advanced Audit Policy for directory service access (Event IDs 4662, 5136) to detect GPO modifications. Deploy GPO change	M1026, M1047

	and GPO Access	observed, potentially allowing the attacker to inspect or modify Group Policy Objects for persistence or payload deployment.	monitoring through a SIEM or dedicated AD monitoring tool. Review all existing GPOs for unauthorised modifications, particularly Groups.xml and Registry.xml entries.	
M6	Restrict and Monitor DNS Resolution for Uncategorised External Domains	47 DNS queries for temp.sh originated from the compromised host, providing an early-warning signal of exfiltration that was not acted upon.	Configure internal DNS resolvers to forward queries through a DNS filtering service that blocks newly registered, uncategorised, and known-malicious domains. Log all DNS queries centrally and create SIEM detections for internal hosts querying domains associated with file-sharing or anonymity services.	M1031, M1037

Strategic Long Term (3-6+ Months)

#	Recommendation Title	Business Risk	Technical Description	MITRE ATT&CK Mitigation
L1	Build a Zero Trust Remote Access Roadmap	If the company continues to trust users once they are “on the network,” one compromised account can still become a	Move away from perimeter trust and broad network access. Evaluate ZTNA platforms that grant per-application access based on identity, device posture, and policy, rather than placing remote users onto the internal network. Prioritize finance systems, TMS/WMS platforms, admin tooling, and backup consoles first.	M1035

		business-wide incident.		
L2	Run Quarterly Tabletop Exercises and Establish an IR Retainer	Poor crisis handling can increase operational downtime, destroy evidence, and delay executive decisions during the next event.	Develop a ransomware playbook with clear decisions on isolation, evidence preservation, external communications, law enforcement, insurer notification, and executive approvals. Run quarterly tabletops with IT, legal, operations, and leadership. Maintain an out-of-band communications plan and a pre-approved IR retainer for 24x7 specialist support.	M1060
L3	Expand Security Awareness into Credential Hygiene Training	Staff who reuse passwords or store them insecurely increase the chance that valid corporate credentials are sold or reused by an access broker.	Keep awareness training focused on behaviors relevant to this intrusion: password-manager use, no reuse between personal and corporate services, reporting of password-reset prompts, and handling of MFA fatigue or suspicious remote access prompts. Include privileged-user modules for IT staff.	M1017
L4	Enforce MFA on All Remote Access	If passwords are stolen again, an attacker can re-enter the environment with little resistance and repeat the intrusion.	Require MFA on every remote access path: VPN, RD Gateway, RDP broker, OWA/webmail, admin portals, and any cloud identity portal. Use phishing-resistant MFA first: FIDO2/WebAuthn hardware keys for admins and IT; TOTP authenticator apps as the minimum fallback. Do not permit SMS-based MFA except as a temporary break-glass method with separate approval. Apply	M1032

			conditional access for impossible travel, new device, and high-risk sign-in events.	

Appendix Timeline

Date / Time (UTC)	Phase	Activity
2025-03-01 18:20:01 - 23:25:36	**Reconnaissance**	External RDP spray activity: 170 IPs generate 52,911 inbound RDP connection attempts to 10.128.239.57:3389. Sources include 141.98.11.170 (6,589 attempts), 194.0.234.17 (6,512), and 45.140.17.72 (1,592 with hostname-aware cookie jjjjjjjRD).
2025-03-01 23:25:07	**Initial Access**	Attacker IP 195.211.190.189 (AS214943 Railnet LLC) initiates low-volume inbound RDP session to 10.128.239.57:3389. The first appearance of a confirmed intrusion source.
2025-03-01 23:25:36	**Initial Access**	RDP session from 195.211.190.189 observed with cookie lgallegos, confirming credential-bearing access to beachhead host.
2025-03-01 23:25:43	**Credential Validation**	Successful Kerberos AS request for lgallegos/water.domain-ees3Ai.local from 10.128.239.57 to DC 10.128.239.23:88 credentials validated within 6.97 seconds of RDP access.
2025-03-01 23:25:43 - 23:26:47	**Discovery**	Domain enumeration via LSARPC, LDAP, and DRSUAPI from 10.128.239.57 to DC 10.128.239.29 name resolution, SID lookup, and directory queries.
2025-03-01 23:30:38	**Lateral Movement**	NTLM authentication as WATER\LGallegos from 10.128.239.57 to 10.128.239.27:445, followed by SMB administrative share access (IPC$, ADMIN$, C$).
2025-03-01 23:30:40 - 23:31:00	**Lateral Movement**	Mass SMB admin-share probing: 449 delete.me file operations (create/delete) across 133 internal hosts from 10.128.239.57 automated write access validation via ADMIN$ (62 hosts) and C$ (43 hosts).
2025-03-01 23:30:00	**Discovery (Wave 1)**	First discovery wave: 2,060 SMB connections and 967 SAMR packets targeting 131 unique hosts across 10.128.239.0/24 subnet.
2025-03-02 00:20:11	**Lateral Movement**	First internal RDP pivot from beachhead 10.128.239.57 to 10.128.239.64:3389.
2025-03-06 22:50:00	**Discovery (Wave 2)**	Second discovery wave: 5,956 SMB connections and 898 SAMR packets targeting 125 unique hosts largest SMB enumeration wave.
2025-03-06 22:41:51	**Credential Access**	bkrp_BackupKey invoked via \\pipe\\lsass over SMB from 10.128.239.57 to DC 10.128.239.23 DPAPI backup key extraction.

Date / Time (UTC)	Phase	Activity
2025-03-06 22:50:00 - 23:00:00	**Exfiltration (Staging)**	SMB file access begins on file server 10.128.239.37: 27,305 total file access events including DC backups, credential databases, credit card records, and law enforcement PII.
2025-03-06 23:00:00	**Exfiltration**	DNS queries for temp.sh from 10.128.239.57 (47 total queries observed). First TLS 1.3 connection to temp.sh (51.91.79.17) 11 encrypted HTTPS sessions upload 1,033 MB of data.
2025-03-06 23:04:53 - 23:13:44	**Reconnaissance**	Attacker accesses backup infrastructure: backup directories on 10.128.239.39 (Veeam, SAFETY domain VMs), 10.128.239.36 (root DCs DC1, DC3), and 10.128.239.35 (ADMIN domain DC7) via SMB.
2025-03-06 23:05:50 - 23:06:23	**Payload Transfer**	First executable transfer wave: Suricata ET INFO SMB2 NT Create AndX alerts from 10.128.239.57 to 10.128.239.36.
2025-03-06 23:12:12 - 23:12:38	**Payload Transfer**	Second executable transfer wave to 10.128.239.34. Zeek records 10.128.239.57 opening \\10.128.239.34\software\hfs.exe.
2025-03-06 23:13:49+	**Payload Transfer**	Largest executable transfer wave to 10.128.239.37. SMB Find Response from 10.128.239.98 reveals kkwlo.exe, hfs.exe, and hfs.ips.txt strongest ransomware payload candidates.
2025-03-08 08:22:00	**Discovery (Wave 3)**	Third discovery wave: 3,023 SMB connections and 1,674 SAMR packets targeting 134 unique hosts. RDP SYN scanning: 514 packets to 153 unique internal hosts on port 3389.
2025-03-08 08:21:04	**Interactive RDP**	Prolonged inbound RDP session from external IP 77.90.153.30 to 10.128.239.57 approximately 67 minutes duration (~24.7 MB received, ~4.9 MB sent).
2025-03-08 08:22:04	**Access Validation**	delete.me open/delete operations resume from 10.128.239.57 across 131 internal hosts final write-access validation before deployment.
2025-03-08 09:06:19	**Defense Evasion**	UninstallWinClient.exe opened on 10.128.239.66 via SMB, followed by iteration through Program Files on 10.128.239.47 suspected security software removal (T1562.001).
2025-03-08 09:06+	**Impact**	Ransomware deployment phase: interactive RDP sessions from 10.128.239.57 to .34, .35, .36, .37, .39, and .176 for manual encryption execution. Ransom note HOW TO BACK FILES.txt present in SMB directory listings.

Appendix Timesheet & Work Breakdown

Consultant Name	Activity Performed	Time Incurred
Koh Nicholas	Analyzed payload deployment via SMB lateral tool transfer, identified suspicious executables (kkwlo.exe, hfs.exe), and drafted Section D findings	**25 Hours**
Kuan Joy	Investigated ransomware deployment methodology, correlated RDP sessions with SMB executable transfers, and co-authored Section D	**22 Hours**
Jasmine Tye	Mapped initial access timeline from Zeek RDP/Kerberos/NTLM logs, analyzed credential validation sequence, and co-authored Section A	**24 Hours**
Liu Cong	Led data exfiltration analysis (Section C), quantified 1,033 MB upload to temp.sh via TLS 1.3, identified 27,305 SMB file access events, and correlated DNS/TLS/TCP evidence	**27 Hours**
Phoebe Lee	Investigated SMB file access patterns on file server .37, catalogued compromised data categories (credentials, DC backups, law enforcement PII), and co-authored Section C	**25 Hours**
Yong Yik Sheng	Analyzed archive compression and staging workflow, mapped exfiltration infrastructure (temp.sh), correlated TLS SNI with DNS queries, and co-authored Section C	**24 Hours**
Tan Jess	Analyzed payload transfer and delete.me write-testing patterns across 135 hosts, investigated defense evasion via GPO manipulation, and co-authored Section D	**23 Hours**
Ong Hong Xun	Analyzed Suricata alert correlation with Zeek logs for initial access, verified pre-intrusion reconnaissance patterns, and co-authored Section A	**22 Hours**
Ong Chun Wei	Managed project scope, compiled MITRE ATT&CK mapping, structured the final report, drafted executive summary and conclusion, and compiled the timesheet	**28 Hours**
Total Project Time		**220 Hours**